

ПОДГОТОВКА К ЭКЗАМЕНУ

Защита информации

Криптография · криптопротоколы · информационная безопасность

Структурированный конспект по экзаменационным вопросам

Сборка по рукописным материалам · 21 вопрос

Формулы, схемы и определения восстановлены и оформлены

Содержание

1.1 Информационные войны. Цели защиты, уязвимости

1.2 Многоалфавитная замена. Одноразовый блокнот

3.1 Методы авторизации доступа

3.2 Алгоритмы шифрования «Магма» и DES

4.1 Виды каналов утечки информации

4.2 Односторонние функции. Аутентификация

5.1 Резервное копирование. RAID-массивы

5.2 Защита от словарной атаки

6.1 Компьютерные атаки и тестирование защиты

6.2 Односторонние функции с секретом

7.1 Человеческий фактор в защите ИС

10.1 Защита авторских прав на информацию

10.2 Гибридные криптосистемы

11.2 Понятие криптопротокола

12.1 Криптография и стеганография

12.2 Атака «человек посередине»

13.1 Подстановки и перестановки

13.2 «Подбрасывание монеты» и «слепая подпись»

14.1 Одноалфавитная замена. Шифр Цезаря

14.2 «Игра в карты по телефону» (ментальный покер)

Основы и классические шифры

Вопрос 1.1 Информационные войны. Цели защиты информации, причины уязвимости систем

Информационная война — противоборство государств, организаций или группировок в информационном пространстве с целью нарушения их работы, нанесения ущерба информационным системам, процессам и ресурсам, а также принуждения к принятию решений в свою пользу.

Основные методы информационной войны:

- атаки на системы, содержащие данные, с целью их **стирания**;
- **физическое повреждение** накопителей данных;
- **кража данных** или их **фальсификация** с целью дальнейшего манипулирования.

Цели защиты информации:

1. обеспечение **конфиденциальности**;
2. обеспечение **целостности** данных;
3. обеспечение **аутентификации** доступа к данным;
4. обеспечение **невозможности отказа** от авторства или ложного приписывания авторства (неотказуемость);
5. обеспечение **неотслеживаемости** действий пользователей.

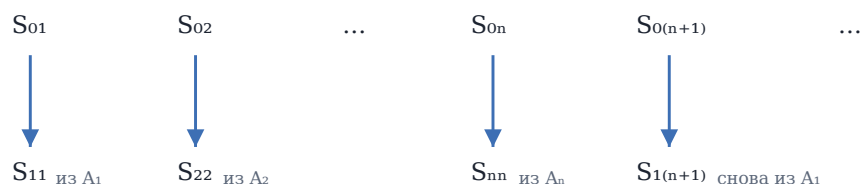
Причины уязвимости систем:

1. несовершенство протоколов защиты;
2. недостаток вычислительных ресурсов;
3. неправильное или неполное применение защитных протоколов;
4. несогласованность работы компонентов системы;
5. недобросовестность сотрудников / социальная инженерия.

Вопрос 1.2 Многоалфавитная замена. Одноразовый блокнот

Многоалфавитная замена — шифрование, при котором один и тот же символ исходного текста заменяется по разным алфавитам в зависимости от позиции.

Пусть заданы N алфавитов $\{A_0, A_1, \dots, A_N\}$, и исходный текст записан алфавитом A_0 в виде $S_{01} S_{02} \dots S_{0N} \dots$. Тогда каждый символ заменяется по «своему» алфавиту, циклически:



Циклическое чередование алфавитов при многоалфавитной замене

Пример — таблица Тритемия (каждая строка — алфавит, сдвинутый на одну позицию):

A	B	C	D	...	W
B	C	D	E	...	A
C	D	E	F	...	B
D	E	F	G	...	C
⋮	⋮	⋮	⋮	⋮	⋮
W	A	B	C	...	Z

Одноразовый блокнот Шеннона. Пусть задан открытый текст $m = m_0 m_1 \dots m_{n-1}$ длины n и случайная шифрующая последовательность $k = k_0 k_1 \dots k_{n-1}$ такой же длины. Тогда шифртекст $c = c_0 c_1 \dots c_{n-1}$ получается поэлементно:

$$c = m \oplus k \text{ (поэлементное сложение по модулю 2)}$$

Уточнение • Шифр абсолютно стойкий (доказано Шенноном) только при выполнении условий: ключ **истинно случайный**, **равен по длине** сообщению и **используется однократно**. Эффективен при достаточно больших n , когда ключ k нельзя перебрать.

Доступ, блочные шифры, каналы утечки

Вопрос 3.1 Методы авторизации доступа к ресурсам вычислительных систем

1. **Имя и пароль**, заранее выданные пользователю (при необходимости дополняются сессионным ключом — например, JWT-токеном).
2. **Проверка нахождения** пользователя в определённой локальной или виртуальной сети.
3. **Нестандартный формат доступа** к вычислительным ресурсам, известный только доверенному лицу.
4. Использование **специального устройства-ключа** (аппаратный токен, смарт-карта).
5. Определение **местоположения** пользователя.
6. Определение **биометрических данных** пользователя.

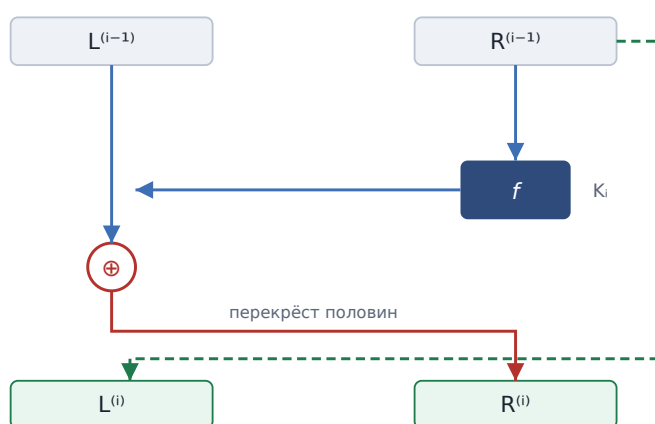
Вопрос 3.2 Алгоритмы шифрования «Магма» и DES

DES (Data Encryption Standard)

Исходный текст разбивается на **64-битные блоки**, фиксируется **56-битный ключ K**. Используя **сеть Фейстеля**, на протяжении **16 раундов** над блоком выполняются преобразования:

1. входной 64-битный блок делится на две половины $L_{32}^{(0)}$ и $R_{32}^{(0)}$;
2. для каждого раунда i вычисляется образующая функция f от правой половины и раундового подключа K_i (48 бит);
3. половины пересчитываются и меняются местами по формулам Фейстеля.

$$L_{32}^{(i)} = R_{32}^{(i-1)}; \quad R_{32}^{(i)} = L_{32}^{(i-1)} \oplus f(R_{32}^{(i-1)}, K_i)$$



Один раунд сети Фейстеля: $R_{32}^{(i-1)}$ входит в f и одновременно «уходит» влево ($L_{32}^{(i)}$); результат $\oplus$ становится правой половиной

Достоинства +

быстрая аппаратная реализация; чёткий, проверенный стандарт.

Недостатки –

короткий ключ (56 бит); низкая криптостойкость по современным меркам.

ГОСТ 28147-89 «Магма»

В значительной степени совпадает с DES, так как **также основан на сети Фейстеля**, но имеет **более сложную функцию f** с таблицами подстановки (S-блоки) и **составной ключ $8 \times 32 = 256$ бит**.

Достоинства +

значительно более стойкий, чем DES (длинный ключ).

Недостатки –

более медленный.

Вопрос 4.1 Виды каналов утечки информации

1. **Вредоносное программное обеспечение.**
2. **Недобросовестный (скомпрометированный) персонал.**
3. **Незащищённое сетевое соединение.**
4. **Скомпрометированный участник** обмена информацией.
5. **Аппаратные закладки** в вычислительной системе.
6. Канал связи, **скомпрометированный в результате атаки.**

Односторонние функции, целостность, атаки

Вопрос 4.2 Односторонние функции. Аутентификация с их использованием

Односторонняя функция f — такая, что значение $y = f(x)$ **легко вычислимо**, а обратное $x = f^{-1}(y)$ **вычислить практически невозможно**.

Применяется в алгоритмах вычисления **электронной цифровой подписи** (RSA, Эль-Гамаль) для однозначного определения подлинности сообщения.

Пример (схема подписи на базе RSA, по конспекту):

1. генерируются ключи по модулю n : x — открытый показатель, y — секретный показатель;
2. пусть m — исходный текст; вычисляем подпись: $s = m^y \bmod n$;
3. в сообщение записываем пару $m + s$;
4. проверяем подпись: $m' = s^x \bmod n$;
5. если $m' = m$, то сообщение **подлинно**.

Эти функции односторонние, так как восстановить секретный показатель можно лишь взяв **дискретный логарифм по модулю n** , а это практически невозможно.

Уточнение · В каноническом RSA модуль $n = p \cdot q$ (p, q — простые), показатели связаны соотношением $x \cdot y \equiv 1 \pmod{\phi(n)}$. Подпись $s = m^y \bmod n$ создаётся секретным ключом, а проверка $m' = s^x \bmod n$ — открытым. Прямая стойкость опирается на сложность **факторизации** n ; конспектная формулировка через дискретный логарифм относится скорее к схеме Эль-Гамала.

Вопрос 5.1 Резервное копирование. RAID-массивы

Для обеспечения **целостности данных** необходимо выполнять их **резервное копирование** с возможностью восстановления и с определённой частотой. В этом помогают **RAID** — *Redundant Arrays of Independent Disks* (избыточные массивы независимых дисков).

Возможные конфигурации:

RAID 0

чередование

1

2

3

4

5

6

7

8

нет избыточности

RAID 1

зеркалирование

1

1

2

2

3

3

4

4

полная копия

RAID 5

данные + контроль чётности

a0

a1

a2

Kc3

b0

b1

Kc2

b3

c0

Kc1

c2

c3

Kc0

d1

d2

d3

Kc — контрольная сумма всего ряда (строки)

RAID 0 — скорость без избыточности · RAID 1 — зеркало · RAID 5 — распределённая чётность. Существуют также RAID 10/01 и многие другие.

Вопрос 5.2 Методы защиты от словарной атаки на односторонние функции

1. использование **сессионных ключей** и **временных меток**;
2. использование **случайных вставок** в исходном тексте (соль) для усложнения построения словаря;
3. **многократное применение** односторонней функции, причём разное число раз для разных параметров.

Уточнение · Случайная вставка («соль») и многократное хеширование («растяжение ключа») делают заранее построенные радужные таблицы и словари бесполезными, так как одно и то же значение даёт разный результат.

Вопрос 6.1 Примеры и методология компьютерных атак.

Тестирование защиты

1. **Атака на криптопротокол** с целью определения криптопреобразования и перехвата / дешифровки секретной информации (линейный и дифференциальный анализ).
2. **Атака «человек посередине»** — злоумышленник берёт под контроль канал связи и подделывает сообщения корреспондентов.
3. **Атака на вычислительный ресурс** через вредоносное ПО, замаскированное под безвредное, с целью перехвата / удаления информации.

Все эти атаки и их подвиды могут **симулироваться** для тестирования системы защиты информации (пентест).

Вопрос 6.2 Односторонние функции с секретом. Труднорешаемые математические задачи

Односторонняя функция с секретом — односторонняя функция $f(x)$, для которой, если известны определённые «секретные» значения, обратная функция f^{-1} вычисляется **быстро**.

Пример. В RSA секретом является разложение большого числа n на два простых множителя.

Труднорешаемая задача — задача, для которой **не существует эффективного общего алгоритма** решения (полиномиального).

Криптография опирается на такие задачи:

1. **Дискретное логарифмирование** по модулю n .
2. **Разложение числа на простые множители** (факторизация) по модулю n .
3. **Поиск корней уравнения эллиптической кривой** в поле Галуа $GF(2^n)$.

Вопрос 7.1**Влияние человеческого фактора на защиту информационных систем****Позитивное влияние +**

- **а)** в силу принципиальности / дотошности сотрудник может выдвигать более жёсткие (оправданные) требования к выбору и эксплуатации криптопротоколов;
- **б)** в силу нестандартного мышления может найти и устранить ранее неизвестную лазейку.

Негативное влияние –

- **в)** из-за утомляемости и большой умственной нагрузки может не до конца (без должного внимания) выполнять требования криптопротоколов;
- **г)** может быть обманут злоумышленником методами социальной инженерии;
- **д)** может быть нелояльным (недобросовестным).

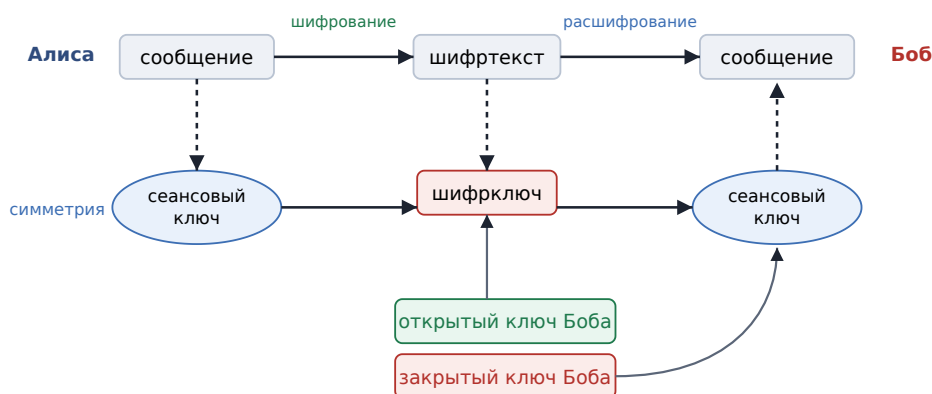
Криптопротоколы и системы

Вопрос 10.1 (= 11.1) Методы защиты авторских прав на информацию

1. **Проверка лицензии** методом зашифрования под устройство пользователя (привязка к «железу»).
2. Внесение **специализированных меток** в физический носитель информации.
3. **Нестандартный формат** нанесения информации на носитель, известный только доверенным лицам.
4. **Прочный защитный «конверт»**, допускающий к информации только в своей среде (DRM-контейнер).
5. **Спящие контрольные точки**, требующие ключ.
6. **Мягкая деградация** функционала ПО по истечении пробного периода.
7. **Косвенно-психологическое склонение** пользователя к легальному доступу к информации.

Вопрос 10.2 Гибридные криптосистемы

Гибридная криптосистема сочетает **асимметричное** и **симметричное** шифрование: данные шифруются быстрым симметричным алгоритмом на **сеансовом ключе**, а сам сеансовый ключ передаётся защищённо с помощью асимметричной схемы (на ключах получателя).



Сообщение шифруется сеансовым ключом (симметрично); сам сеансовый ключ защищается ключами Боба (асимметрично)

Зачем это делается:

1. **а)** уменьшить вычислительные расходы по сравнению с чисто асимметричным шифрованием;
2. **б)** сделать симметричное шифрование более безопасным (безопасная доставка ключа).

Вопрос 11.2 Понятие криптопротокола

Криптопротокол — набор правил и процедур, регулирующих поведение участников операций, которые используют криптографические методы защиты информации.

Важное свойство: криптопротоколы **не требуют доверия** между участниками.

Типовые участники протоколов:

Alice, Bob	абоненты (легальные стороны обмена)
Eve	пассивный злоумышленник (только подслушивает)
Mallory	активный злоумышленник (вмешивается, подделывает)
Trent	доверенный посредник (арбитр)
Peggy	претендент на истинность (доказывающий)
Victor	проверяет правоту Peggy (верификатор)

Примеры: AES, «Кузнечик», HTTPS, обмен ключами Диффи — Хеллмана (DH), RSA, ЭЦП Эль-Гамала.

Вопрос 12.1 Криптографические и стеганографические методы защиты информации

Криптография — сокрытие / затруднение восприятия передаваемой информации (содержание скрыто, но факт передачи виден).

Стеганография — сокрытие *самого факта* передачи секретной информации.

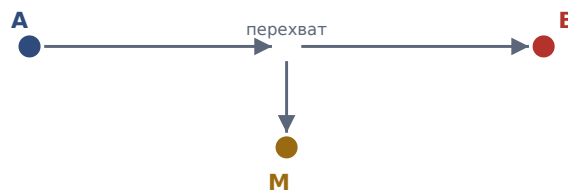
Криптография использует шифры: Цезаря, одно- и многоалфавитной замены, одноразовый блокнот и др.

Способы стеганографии:

1. **Соккрытие бит** в неатрибутных (избыточных) форматах файлов, например, BMP.
2. Использование внешне **безобидных фраз / сигналов** со скрытым смыслом.
3. **Манипулирование оборудованием** (например, скоростью вращения процессорного кулера) для тайной передачи заранее оговорённых сигналов — побочный канал.

Вопрос 12.2 Атака на криптопротоколы «человек посередине» (MITM)

Атака заключается в **компрометации канала связи**, перехвате и подделке сообщений с целью манипулирования абонентами. Злоумышленник М встаёт между А и В, выдавая себя перед каждым за другую сторону.



М перехватывает и ретранслирует трафик между А и В

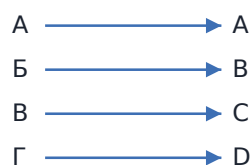
Методы защиты:

1. **ЭЦП** в сообщениях (подтверждение подлинности отправителя);
2. использование **VPN-туннелирования**;
3. **передача хэшей** сообщений (контроль целостности).

Вопрос 13.1 Подстановки и перестановки. Примеры ранних систем шифрования

Шифр подстановки

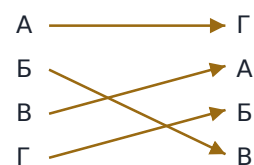
меняется алфавит (символы)



Примеры: 1) шифровальный диск; 2) геометрический шифр (алфавит выписан в строку, снизу по вертикали отложены расстояния до выбранных букв, из которых складываются фигуры).

Шифр перестановки

меняется порядок символов



Примеры: 1) шифр «Считала» (скитала); 2) маршрутная перестановка (запись в таблицу и считывание в другом порядке); 3) задача Эйлера об обходе шахматной доски (развитие маршрутной перестановки).

Вопрос 13.2 Криптопротоколы «подбрасывание монеты» и «слепая подпись»

Подбрасывание монеты

Честный случайный выбор между двумя удалёнными сторонами, не доверяющими друг другу.

1. Пусть $f(x)$ — односторонняя. Алиса выбирает случайное x , вычисляет $y = f(x)$ и посылает y Бобу.
2. Боб пытается угадать **чётность** x и сообщает Алисе своё предположение.
3. Алиса посылает Бобу x , сообщая, угадал он или нет.
4. Боб может проверить, что действительно $y = f(x)$ (Алиса не смогла смошенничать).

Слепая подпись

Боб подписывает документ, не зная его содержания (схема «разрезать и выбрать»).

1. Алиса создаёт **N экземпляров** M_i с различными атрибутами идентификации и столько же **масок** r_i . Бобу отправляются замаскированные документы $r_i \cdot M_i$.
2. Боб выбирает **$N-1$** документ и просит у Алисы их маски.
3. Получив $N-1$ маску, Боб проверяет подлинность этих документов; затем **оставшийся** документ подписывает: $S(r \cdot M)$ — и отправляет Алисе.
4. Для проверки Алиса предъявит набор $\{ S(r \cdot M), r, M \}$.

Вопрос 14.1 Одноалфавитная замена. Шифр Цезаря

Шифр Цезаря — исторический пример шифра **одноалфавитной замены**, при котором исходному тексту $(A_{01}, A_{02}, \dots, A_{0n})$, записанному в алфавите A_0 , сопоставляется текст $(A_{11}, A_{12}, \dots, A_{1n})$ в алфавите A_1 .

Преобразование $\varphi: A_0 \rightarrow A_1$ — это просто **циклический сдвиг** на k позиций влево (или вправо).

$$A_{1i} = (A_{0i} + k) \bmod |\text{алфавита}|$$

Уточнение • «Одноалфавитная» означает, что весь текст шифруется одним и тем же сдвигом, поэтому шифр легко вскрывается частотным анализом: относительные частоты букв сохраняются.

Вопрос 14.2 Криптопротокол «игра в карты по телефону» (ментальный покер)

Рассматривается вариант алгоритма «**без перетасовки**», так как на текущий момент он обеспечивает более высокую производительность. Цель — честно раздавать карты без доверенного дилера.

1. Алиса и Боб создают пустой список $L = \{\}$, в котором будут фиксироваться уже использованные карты.
2. Чтобы взять карту, Алиса случайно выбирает r_i из $\{0, 1, \dots, 51\}$ и вычисляет $E(r_i)$ — например, методом Эль-Гамала.
3. То же делает Боб: вычисляет $E(r_{i+1})$. Алиса может его проверить (или Боб — проверить Алису).
4. Игроки вычисляют произведение шифртекстов — гомоморфное свойство даёт сумму показателей:

$$E(r_i) \cdot E(r_{i+1}) = E(r_i + r_{i+1}) = E(r^*)$$

где r^* — следующая карта.

5. Если r^* нет в L , то Алиса разыгрывает r^* и добавляет $E(r^*)$ в L .
6. Когда карты раскрываются, список L дешифруется: $E(r^*) \rightarrow r^*$ для всех $r^* \in L$.

Уточнение • Использование гомоморфного шифрования ($E(a) \cdot E(b) = E(a+b)$) позволяет складывать «закрытые» случайные числа обоих игроков, так что итоговую карту не может предсказать ни одна из сторон в одиночку.